

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 **COURSE NAME:** Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 50

Annexure A

Industry Problem-Solving Task

Code of Conduct:

*I Gurusurya G 192311332 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Gurusurya
Signature of the student:

Annexure A Industry Problem-Solving Task

Industry Problem-Solving Case Studies

IPSec Architecture, Key Management, Secure Email (PGP/S-MIME), Spam Detection and Certificate Trust Management

1. Enterprise IPSec Deployment: AH and ESP Configuration

A multinational enterprise connecting branch offices over the public internet must protect data against eavesdropping, tampering, and impersonation. IPSec provides this protection through two core protocols, Authentication Header (AH) and Encapsulating Security Payload (ESP), which can be deployed individually or together depending on the confidentiality and integrity requirements of the traffic class involved.

Because branch offices typically sit behind different Internet Service Providers, on different continents, and behind NAT-enabled edge routers, the design must also account for public-address translation, variable link latency, and the fact that a single misconfigured policy can silently degrade an entire region's connectivity. The recommendations below therefore treat IPSec design as a per-traffic-class exercise rather than a single organization-wide setting, so that the strongest protection is applied where it is legally or operationally required, while lower-risk traffic is not burdened with unnecessary processing overhead.

Task A: Identify which traffic requires AH, ESP, or both

Not all branch-office traffic carries the same sensitivity, so a single blanket IPSec policy is inefficient. Traffic should first be classified, and the classification then mapped to a protocol choice.

Traffic Category	Sensitivity	Recommended Protocol	Rationale
Financial transaction data, ERP/CRM records	High confidentiality + integrity	ESP (encryption + authentication)	Data must remain unreadable in transit and must not be altered
Inter-branch routing updates, network management (SNMP, syslog)	High integrity, low confidentiality	AH	Source authenticity and tamper detection are critical; content is not secret
VoIP and video conferencing	Medium confidentiality, latency sensitive	ESP (encryption only, no auth overhead)	Confidentiality matters but heavy authentication overhead harms real-time performance
Regulatory / compliance file transfers (e.g., audit logs to HQ)	High confidentiality + integrity + non-repudiation	AH + ESP combined, or ESP with authentication	Both origin authenticity and payload secrecy are legally required
General web/browsing traffic between branches	Low to medium	ESP in tunnel mode (encryption)	Basic confidentiality sufficient; simpler to manage centrally
DNS and directory replication traffic	Medium integrity	AH	Must guarantee the update truly originated from a trusted branch server

Key principle: ESP alone (with its optional authentication field) already provides both confidentiality and integrity for the encapsulated payload, so ESP is used for the majority of enterprise traffic. AH is reserved for scenarios where the IP header itself, not just the payload, must be authenticated end-to-end, such as anti-spoofing protection for management and routing traffic that must survive audit scrutiny even though it is not confidential.

A practical classification exercise should also consider data-in-motion regulations that differ by jurisdiction. For a multinational enterprise, transfers that cross a border where data-protection law (such as GDPR in the European Union or similar statutes elsewhere) applies should default to the strongest available protection (ESP with strong AEAD ciphers, and AH where header authenticity is separately required) regardless of the traffic's perceived

internal sensitivity, since the compliance obligation is triggered by the border crossing itself rather than by the content alone.

Task B: Design packet flow with appropriate IPSec modes (transport/tunnel)

IPSec supports two modes. Transport mode protects only the payload of the original IP packet and is used for end-to-end host-to-host communication inside a trusted network. Tunnel mode encapsulates the entire original IP packet inside a new IP packet and is the standard choice for gateway-to-gateway VPNs across the public internet, because it hides the internal addressing scheme of each branch.

Recommended packet flow

- Branch A host generates a packet addressed to a host in Branch B (private internal IP addressing).
- The Branch A IPSec gateway (VPN router/firewall) intercepts the packet based on its Security Policy Database (SPD).
- The gateway applies ESP in tunnel mode: the entire original packet (header + payload) is encrypted and encapsulated inside a new IP packet whose source/destination are the public IP addresses of the two gateways.
- If the traffic class also requires AH (e.g., compliance transfers), AH is applied after ESP encapsulation so that the outer tunnel header is also authenticated, forming AH(ESP(original packet)).
- The packet traverses the public internet to the Branch B gateway.
- The Branch B gateway verifies AH (if present), decrypts and authenticates the ESP payload, strips the tunnel header, and forwards the original packet to the internal destination host.
- Throughout the exchange, the Security Policy Database (SPD) at each gateway determines whether a given packet should be discarded, forwarded in the clear, or processed by IPSec, while the Security Association Database (SAD) supplies the specific keys and algorithms once IPSec processing is selected, so both databases must be kept consistent across every gateway pair for the flow to succeed.

For intra-branch host-to-host traffic that never leaves the trusted LAN but still needs protection (for example, a database server talking to an application server on the same segment, where regulation requires encryption in transit even locally), transport mode ESP is appropriate because both endpoints are the actual communicating hosts and there is no need to hide internal topology.

Design summary table

Scenario	Mode	Protocol	Encapsulation Result
Branch-to-branch VPN (gateway to gateway)	Tunnel	ESP	New IP header + ESP header + encrypted original IP packet + ESP trailer/auth
Branch-to-branch compliance transfer	Tunnel	AH + ESP	New IP header + AH + ESP header + encrypted original packet
Server-to-server inside a branch LAN	Transport	ESP	Original IP header + ESP header + encrypted payload
Routing/management protocol between gateways	Transport	AH	Original IP header + AH + payload (unencrypted, authenticated)

Task C: Justify protocol selection for different data types

Financial and customer data (ESP): confidentiality is a regulatory obligation (e.g., PCI-DSS, GDPR-equivalent data protection). ESP's encryption (AES-256-GCM recommended) combined with its integrated ICV (Integrity Check Value) satisfies both secrecy and tamper-detection in a single protocol, minimizing header overhead compared to stacking AH on top.

Routing and management traffic (AH): the content of a routing update is not secret, but an attacker forging a fake update could redirect traffic or cause outages. AH authenticates the entire outer packet, including fields ESP does not cover, giving stronger assurance against spoofing and replay for this narrow but operationally critical traffic class.

Real-time voice/video (ESP, encryption-only): AH's mandatory full-packet authentication and ESP's optional authentication both add per-packet CPU cost. For latency-bound UDP media streams, ESP configured with encryption but with a lightweight authentication algorithm (or relying on a separate integrity mechanism at the application layer) balances confidentiality with acceptable jitter.

Compliance/audit transfers (AH+ESP): when both non-repudiation of origin at the IP layer and payload secrecy are contractually mandated, nesting AH over ESP tunnel mode provides defense in depth, at the cost of extra processing; this is acceptable because such transfers are typically scheduled, non-interactive batch transfers rather than latency-sensitive.

General traffic (ESP tunnel mode): provides a simple, uniform baseline of confidentiality for the bulk of inter-branch traffic without the administrative burden of maintaining separate AH policies for low-risk flows.

Task D: Evaluate performance vs security trade-offs

Configuration	Security Strength	Performance Impact	Best Fit
ESP (encryption + auth, AES-GCM)	High confidentiality + integrity in one pass	Low-moderate (AEAD ciphers combine both operations efficiently)	Default for most enterprise traffic
AH only	Strong header/origin authentication, no confidentiality	Low (no encryption cost) but breaks with NAT traversal	Routing/management traffic on non-NAT links
AH + ESP nested	Maximum assurance, defense-in-depth	High (double header processing, largest packet overhead)	Regulatory/compliance batch transfers only
ESP encryption-only, no auth field	Confidentiality only, vulnerable to tampering unless upper-layer integrity exists	Lowest overhead of the ESP options	Real-time media where jitter is critical and a codec/SRTP layer supplies integrity

In practice, most enterprises standardize on ESP with AES-256-GCM in tunnel mode for gateway-to-gateway VPNs because AEAD ciphers deliver combined confidentiality and integrity at a cost close to encryption alone, making the historical AH-vs-ESP trade-off less relevant than it was with older algorithms. AH is retained selectively for the narrow cases above and is avoided on links that traverse NAT devices, since AH authenticates the IP header itself and any address rewriting by a NAT will invalidate that authentication (NAT-Traversal/UDP encapsulation resolves this for ESP but not cleanly for AH).

Hardware acceleration further shifts this trade-off in the enterprise's favor: modern branch routers and firewalls include dedicated cryptographic co-processors that perform AES-GCM encryption and authentication in hardware, so the marginal cost of enabling ESP on additional traffic classes is typically small relative to the security benefit gained. Where such acceleration is unavailable on legacy branch hardware, the recommended mitigation is to prioritize ESP for the traffic classes identified as high-risk in Task A and to schedule a hardware refresh for branches that would otherwise become a throughput bottleneck under full encryption.

Finally, the design should be validated on an ongoing basis rather than treated as a one-time exercise: as new applications are introduced (for example, a new SaaS-integrated financial reporting tool), the traffic classification table must be revisited so that the correct AH/ESP/mode combination is applied from the outset, rather than defaulting new flows to whatever policy happens to already exist on the gateway.